



University of Piraeus

School of Information and Communication Technologies

Department of Digital Systems

MSc 'Cybersecurity and Artificial Intelligence Technologies'

Information Security Management

Analysis of Risk Management Methodologies and Software Tools for
Information Security

Supervising Professors: K. Lambrinoudakis – S. Gritzalis

Ioannis Kalaitzidis

ioannis_kalaitzidis@ssl-unipi.gr

Piraeus

22/12/2025

Abstract

This thesis provides a comparative analysis of the ISO/IEC 27005:2022 and NIST (SP 800-30 rev.1 and SP 800-39) risk management methodologies, alongside a practical evaluation of four specialized software tools (SimpleRisk, Monarc, Verinice, EAR/PILAR). Theoretical analysis highlights the fundamental contrast between ISO's flexible framework and NIST's structured approach. Concurrently, the practical assessment reveals the gap between theoretical standards and operational reality, offering evidence-based conclusions to guide the selection of the optimal solution based on usability, cost, and compliance requirements.

Contents

1. Introduction.....	5
1.1 Subject and Scope of the Assignment.....	5
1.2 Methodology and Evaluation Criteria.....	5
2. Analysis of the ISO 27005 Methodology.....	
2.1 Identity and Origin.....	7
2.1.1 Issuing Body and Origin.....	7
2.1.2 Current Version.....	7
2.1.3 Legal Nature.....	8
2.1.4 Geographical Scope.....	8
2.1.5 Access Cost.....	9
2.2 Scope and Architecture.....	9
2.2.1 Level of Focus.....	9
2.2.2 Relationship with Other Standards.....	10
2.2.3 Management Cycle.....	11
2.3 Risk Assessment Methodology.....	12
2.3.1 Assessment Approach.....	12
2.3.2 Methodology Flexibility.....	14
2.3.3 Risk Calculation Technique.....	14
2.3.4 Threat/Vulnerability Catalogues.....	15
2.4 Resources and Implementation.....	15
2.4.1 Implementation Complexity.....	16
2.4.2 Required Resources (Implementation Cost).....	16
3. Analysis of the NIST Methodologies (SP 800-30 rev.1 and SP 800-39).....	
3.1 Introduction.....	18
3.2 Identity and Origin.....	18
3.2.1 Issuing Body and Origin.....	18
3.2.2 Current Version.....	19
3.2.3 Legal Nature.....	19

3.2.4 Geographical Scope.....	20
3.2.5 Access Cost.....	21
3.3 Scope and Architecture.....	21
3.3.1 Level of Focus.....	21
3.3.2 Relationship with Other Standards.....	22
3.3.3 Management Cycle.....	23
3.4 Risk Assessment Methodology.....	24
3.4.1 Assessment Approach.....	24
3.4.2 Methodology Flexibility.....	25
3.4.3 Risk Calculation Technique.....	25
3.4.4 Threat/Vulnerability Catalogues.....	26
3.5 Resources and Implementation.....	27
3.5.1 Implementation Complexity.....	27
3.5.2 Required Resources (Implementation Cost).....	28
4. Συγκριτική Αξιολόγηση και Conclusions.....	30
4.1 Consolidated Criteria Table.....	30
4.2 ConclusionsΘεωρητικής Σύγκρισης.....	33
5. Presentation of Software Tools.....	35
5.1 Introduction.....	35
5.2 Tools.....	37
5.2.1 SimpleRisk.....	37
5.2.1.1 Technical Identity and Licensing.....	37
5.2.1.2 Risk Management Functionality.....	39
5.2.1.3 User Experience.....	42
5.2.2 Monarc.....	43
5.2.2.1 Technical Identity and Licensing.....	43
5.2.2.2 Risk Management Functionality.....	44
5.2.2.3 User Experience.....	49
5.2.3 Verinice.....	50
5.2.3.1 Technical Identity and Licensing.....	50
5.2.3.2 Risk Management Functionality.....	51

5.2.3.3 User Experience.....	54
5.2.4 EAR/PILAR.....	54
5.2.4.1 Technical Identity and Licensing.....	55
5.2.4.2 Risk Management Functionality.....	57
5.2.4.3 User Experience.....	60
5.3 Συγκριτική Αξιολόγηση και Conclusions.....	61
6. Bibliography.....	65

1. Introduction

1.1 Subject and Scope of the Assignment

The subject of this assignment falls within the broader field of Information Security Risk Management (ISRM), a process of vital importance for the protection of information assets. In an environment of constantly evolving cyber threats, the systematic identification, assessment and treatment of risks has become a strategic priority for organisations of all sizes.

The purpose of the assignment is the theoretical comparative evaluation of two of the most internationally recognised methodologies: the international standard ISO 27005 and the guidelines of the US National Institute of Standards and Technology (NIST), and specifically SP 800-30 Rev.1 and SP 800-39.

In summary, this study aspires to bridge the gap between the theoretical approach of the standards and their practical application through digital tools, providing documented conclusions for the selection of the appropriate solution based on verifiable criteria.

1.2 Methodology and Evaluation Criteria

For the implementation of the comparative study, a systematic methodological approach was adopted, divided into two phases corresponding to the assignment's objectives: the theoretical analysis of the standards and the practical evaluation of the software tools.

Regarding the first, theoretical part of the assignment (Comparison of ISO 27005 with NIST SP 800-30 rev.1 and NIST SP 800-39), a specialised evaluation framework was developed. In order for the comparison to be objective and structured, four thematic axes were defined, along which each standard was analysed:

1. Identity and Origin:

The 'administrative' characteristics of the documents are examined, such as the issuing body, their legal nature, their geographical scope and the cost of acquisition and use.

2. Scope and Architecture:

The scope of application and the structural philosophy of each framework are analysed. In particular, it is investigated whether the methodology follows a unified approach or is divided into levels, and how it fits into a broader ecosystem of standards.

3. Risk Assessment Methodology:

The technical core of the process is evaluated. Approaches are compared in terms of orientation, the degree of flexibility provided to the organisation, and the proposed risk calculation techniques.

4. Resources and Implementation:

The requirements for implementing each standard are estimated in terms of human resources, technical expertise and complexity, as well as the necessary bureaucratic support.

2. Analysis of the ISO 27005 Methodology

2.1 Identity and Origin

2.1.1 Issuing Body and Origin

The ISO/IEC 27005 standard is published jointly by the International Organisation for Standardisation (ISO) and the International Electrotechnical Commission (IEC), which form the specialised system for worldwide standardisation.

Specifically, this document was prepared by Joint Technical Committee ISO/IEC JTC 1 (Information Technology) and in particular by Subcommittee SC 27, which is responsible for information security, cybersecurity and privacy protection.

2.1.2 Current Version

The current international version of the standard, which is the subject of this study, is the fourth edition and was published in October 2022. It is noted that the standard has been adopted by various national bodies, including the Greek Organisation for Standardisation (ELOT), as ELOT EN ISO/IEC 27005.

2.1.3 Legal Nature

As regards its legal nature, ISO 27005:2022 constitutes an International Standard of voluntary application and not a legal or regulatory provision. The document's preamble makes explicit reference to the voluntary nature of standards.

The character of the document is clearly advisory and not mandatory, as it is defined as 'Guidance' for the management of information security risks. Its purpose is to provide guidance on how to satisfy the requirements of ISO/IEC 27001 with regard to risk management.

2.1.4 Geographical Scope

As an international standard, ISO 27005 has worldwide geographical scope and recognition. The standardisation system formed by ISO and IEC is specialised for global standardisation, allowing adoption by the national bodies of each country.

2.1.5 Access Cost

The ISO/IEC 27005 standard is not freely available, but constitutes a Copyright Protected Document. Ownership belongs to the issuing organisation and distribution without authorisation is prohibited.

In addition to the acquisition cost, implementation of the standard entails internal costs for the organisation, as it requires the commitment of specific resources. According to the document, top management must ensure that the necessary resources are allocated.

The operational cost depends on three key factors identified in the standard:

1. **Funding and Budget:** The conduct of risk assessments must take account of the business budget cycles and be planned in advance so that the necessary funds are secured.
2. **Expertise and Human Resources:** Individuals with the appropriate expertise are required to conduct the tests and analyses.
3. **Technology and Tools:** The choice of assessment methods (e.g. vulnerability checks) depends directly on the available funds and existing technology.

Finally, in the context of continuous improvement, the organisation is called upon to monitor the total cost of ownership of the risk management process.

2.2 Scope and Architecture

2.2.1 Level of Focus

ISO 27005 adopts an approach that runs through the organisation, connecting the strategic level with the operational. Its scope of application is broad and can cover the entirety of an organisation or a specific part of it.

A key characteristic of its focus is the orientation towards business objectives. The very definition of risk in the standard is described as 'the effect of uncertainty on objectives'. This business-centric view differentiates it from other, more technical approaches.

To bridge the gap between strategy and technology, the standard distinguishes assets into two levels:

1. **Primary/Business Assets:** These concern the information and business processes that have value for the organisation.
2. **Supporting Assets:** These concern the components of the information system (Hardware, Software, Networks, Personnel) on which the primary assets depend.

Through this structure, the standard focuses on how the technical vulnerabilities of the supporting assets can affect the business processes, thus covering simultaneously the level of IT management and that of business governance.

2.2.2 Relationship with Other Standards

ISO 27005 does not operate autonomously, but constitutes an integral part of the ISO 27000 family of standards. Specifically, it has been designed to support the implementation of the Information Security Management System (ISMS) as specified in ISO/IEC 27001.

Its role is complementary and advisory. While ISO 27001 sets the requirements for risk management, ISO 27005 provides the guidance on how to satisfy those requirements. The relationship is explicit: ISO 27005 is a supporting document for ISO 27001.

In a broader context, the standard is fully aligned with ISO 31000, which constitutes the general standard for risk management (regardless of sector). ISO 27005 essentially applies the principles of ISO 31000 to the specific domain of information security.

2.2.3 Management Cycle

The architecture of ISO 27005 is not linear, but is based on an iterative approach. The risk management process aligns with the general model of ISO 31000.

The standard explicitly distinguishes two management cycles that must operate in parallel:

- 1. Strategic Cycle: Concerns long-term changes in the organisation's general context, where business assets, risk sources and objectives evolve.**
- 2. Operational Cycle: Concerns shorter timeframes and focuses on the revision and updating of risk scenarios and their treatment, based on new data or changes in the operational environment.**

Finally, the entire process is governed by the principle of Continuous Improvement. The standard requires the risk management process to be continuously monitored, reviewed and improved, so that it remains relevant and effective.

2.3 Risk Assessment Methodology

2.3.1 Assessment Approach

ISO 27005 does not impose a single mandatory method for performing the risk assessment, leaving the organisation free to choose the one that suits its needs. The fundamental requirement is that the chosen approach ensures consistent, valid and comparable results.

a) **Event-based approach: This approach focuses on identifying 'strategic scenarios'. It examines risk sources and how they use or impact interested parties to reach the risk's desired objective.**

- It is ideal for creating high-level scenarios, without requiring the consumption of significant time for the detailed recording of all assets.
- It is often based on discovering the concerns of top management and allows the organisation to focus its treatment efforts on the critical risks.

b) **Asset-based approach: This approach focuses on identifying 'operational scenarios', which are detailed in terms of assets, threats and vulnerabilities.**

- It is based on the concept that risk arises from the examination of an asset, where an asset is anything that has value for the organisation and requires protection.
- This method allows the identification of asset-specific threats and vulnerabilities, leading to the definition of detailed treatment measures.

Relationship between the two approaches: In essence, the two approaches describe the same risk scenario but move in opposite directions. The event-based approach starts from the general level, while the asset-based approach searches upwards from the asset to the scenario. Both lead to a common result.

2.3.2 Methodology Flexibility

The methodology of ISO 27005 is characterised by a high degree of flexibility and a non-prescriptive character. The standard explicitly states that it does not impose a specific approach or method to satisfy the requirements of ISO/IEC 27001.

In contrast to 'prescriptive' standards that define strict mathematical formulas, ISO 27005 operates as a reference framework. It provides the organisation with the discretion to choose between three types of analysis:

1. **Qualitative: Use of descriptive scales (e.g. High, Medium, Low).**
2. **Quantitative: Use of numerical values (e.g. monetary cost or probability of occurrence).**

3. Semi-quantitative: Use of qualitative scales to which values have been assigned.

Although the standard provides samples (Annex A), it explicitly clarifies that these are merely examples. The categories and values presented are not binding. Instead, it is emphasised that the most appropriate value depends on the risk profile and risk appetite of the organisation.

2.3.3 Risk Calculation Technique

The technique for calculating the level of risk in ISO 27005 is not limited to a single algorithm, but can be determined in many possible ways. However, the most common practice is to determine it as a combination of the assessed likelihood and the assessed consequences for all relevant risk scenarios.

- **Asset Value Inclusion: Alternative calculations can explicitly include the asset value as a third parameter, alongside likelihood and consequence.**
- **Non-Linear Calculations: The relationship between the factors is not necessarily linear (e.g. not a simple multiplication but something more complex).**

In any case, the calculation must lead to results that are consistent with the risk criteria established by the organisation during the context establishment phase.

2.3.4 Threat/Vulnerability Catalogues

As regards the identification of risks, ISO 27005 does not impose a closed, mandatory taxonomy, but provides extensive catalogues that function as examples for use during the assessment process.

- **Threat Catalogue (Table A.10): Provides examples of typical threats, which can be used during the threat assessment process. These threats are categorised according to their nature (Deliberate, Accidental, Environmental).**
- **Vulnerability Catalogue (Table A.11): Provides examples of vulnerabilities in various security areas (Hardware, Software, Network, Personnel,**

Facilities, Organisation), as well as examples of threats that can exploit these vulnerabilities.

These catalogues have been designed to provide guidance to the organisation so as to identify the relevant risk scenarios. However, it is emphasised that they are not exhaustive and that in some cases other threats can exploit these vulnerabilities as well.

2.4 Resources and Implementation

2.4.1 Implementation Complexity

The implementation complexity of ISO 27005 stems primarily from its flexibility. Since the standard does not offer ready-made solutions, it requires the organisation to invest significant effort in designing the entire risk management process from scratch.

The organisation is called upon to define on its own the operating parameters, such as the risk criteria (acceptance and assessment criteria), as well as to select the appropriate method that will ensure consistent results.

As regards personnel, the process cannot be carried out mechanically. The involvement of individuals with specialised knowledge in the relevant field is required for the collection of the necessary information and the objective conduct of the assessment.

2.4.2 Required Resources (Implementation Cost)

The implementation of ISO 27005 entails significant operational costs, which do not concern the purchase of the standard or specialist software, but primarily the commitment of human resources and time.

a) Human Resources Commitment and Collaboration: The methodology cannot be implemented by a single individual in isolation. It requires extensive interaction within the organisation:

- **Interviews: Risk identification requires time for interviews with management and those responsible for business processes, in order to identify the relevant events.**

- **Team Assessments:** To increase the reliability of likelihood estimates, the standard proposes the conduct of team assessments rather than individual ones, thereby engaging more human resources.
- **Continuous Communication:** Communication and consultation with interested parties must be continual, not a one-off exercise.

b) Financial Planning: The process is inextricably linked with the organisation's financial cycles. Risk assessments must be planned in advance so as to be incorporated into the relevant budget planning.

c) Documentation (Bureaucracy): The standard imposes strict documentation requirements, as the existence of documented information is mandatory for demonstrating compliance.

- The definition of the criteria and the methodology chosen.
- The results of the assessment (risk lists, risk owners).
- Decisions on treatment and risk treatment plans.

3. Analysis of the NIST Methodologies (SP 800-30 rev.1 and SP 800-39)

3.1 Introduction

In contrast to the ISO 27005 standard, which constitutes a single guidance document, the approach of the US National Institute of Standards and Technology (NIST) is modular and distributed across a series of interconnected Special Publications (SP).

1. **NIST SP 800-39 Rev.1 (Managing Information Security Risk): Defines the general framework for a comprehensive, enterprise-wide risk management process, defining the strategy, governance and structure at all organisational levels.**
2. **NIST SP 800-30 Rev.1 (Guide for Conducting Risk Assessments): Functions as a supporting document, providing specialised guidance exclusively for the conduct of the risk assessment process.**

The combined analysis of these two documents is essential, as SP 800-39 sets the strategic framework while SP 800-30 analyses how to execute the assessment, thereby covering the subject holistically.

3.2 Identity and Origin

3.2.1 Issuing Body and Origin

The Special Publications 800 (SP 800) series documents are published by the National Institute of Standards and Technology (NIST), which is an agency of the US Department of Commerce.

An important element of their origin is that both documents were developed under the Joint Task Force Transformation Initiative — an interagency working group that included representatives from the Civil, Defense and Intelligence Communities.

3.2.2 Current Version

For the purposes of this study, and in order to ensure full compatibility with current requirements, the current, in-force versions of the two documents are examined:

1. **NIST SP 800-39: The current version of the document was published in March 2011. It is worth noting that this document superseded the original version of SP 800-30 as the primary source for risk management guidance.**
2. **NIST SP 800-30 Rev.1: The current version is Revision 1 and was published in September 2012. This revision was issued to align the assessment process with the new SP 800-39 framework.**

3.2.3 Legal Nature

The legal nature of NIST documents differs significantly depending on the organisation applying them, presenting a dual character:

1. **Mandatory Application: For US Federal Agencies, compliance with NIST security standards and guidelines is mandatory and binding under the Federal Information Security Management Act (FISMA).**
2. **Voluntary Application: For non-governmental organisations, academic institutions and private-sector entities (within and outside the US), the use of these documents is optional. However, many organisations adopt them voluntarily because they constitute globally recognised best practices.**

Furthermore, as works of the US federal government, these documents are not subject to copyright within the United States and can be used freely, although NIST requests attribution.

3.2.4 Geographical Scope

Formally, the geographical scope of NIST guidelines is limited to the United States and specifically to the information systems of the federal government. The documents explicitly define their scope of application to federal information systems.

However, their actual scope is global. NIST explicitly encourages state, local and tribal governments, as well as private-sector organisations, to consider using these guidelines, as appropriate.

3.2.5 Access Cost

In complete contrast to ISO standards, which require the purchase of a licence, access to NIST SP 800 series documents is free and publicly available. Both NIST SP 800-39 and NIST SP 800-30 Rev.1 are available free of charge from the NIST website.

3.3 Scope and Architecture

3.3.1 Level of Focus

In contrast to the unified approach of other standards, the architecture of NIST (as defined in SP 800-39) is characterised by a strictly structured, multi-tiered approach. The framework explicitly defines three tiers of risk management:

- 1. Organisation (Tier 1 - Organisation View): This concerns the strategic level. Here, governance, risk management strategy and risk tolerance are defined. Decisions at this level provide the direction for the rest of the organisation.**
- 2. Mission/Business Processes (Tier 2 - Mission/Business Process View): This concerns the mission level. Here, critical business processes are defined and prioritised and the enterprise architecture is designed.**
- 3. Information Systems (Tier 3 - Information Systems View): This concerns the operational/technical level. It focuses on the specific information systems that support the business processes. Here, the categorisation, security control selection and continuous monitoring of the systems take place.**

Communication between the tiers is bidirectional, ensuring that strategy flows down to the systems and information on the state of the systems flows up to management for informed decision-making.

3.3.2 Relationship with Other Standards

The NIST SP 800-39 and SP 800-30 methodologies do not function as autonomous entities, but constitute integral parts of a broader, comprehensive suite of security documents developed by NIST.

- NIST SP 800-39: Explicitly characterised as the flagship document of the series. It sets the strategic framework and guides the other documents.
- NIST SP 800-30 Rev.1: Functions in a supporting capacity to SP 800-39, specialising in the assessment process.

Their implementation is inextricably linked with other critical standards in the family:

- NIST SP 800-37 (Risk Management Framework - RMF): Defines the security lifecycle. The risk assessment (of SP 800-30) is performed at specific stages of the RMF.
- NIST SP 800-53 (Security Controls): Provides the catalogue of security measures. The risks identified with SP 800-30 are addressed through the selection of controls from SP 800-53.

Finally, it is worth noting the explicit intention of harmonisation with international standards. The concepts and principles of these documents have been designed to be compatible with ISO/IEC standards (such as ISO 31000 and ISO 27001), thereby reducing the burden of compliance for organisations that must satisfy both.

3.3.3 Management Cycle

The architecture of NIST does not follow the classic ISO cycle, but defines a specialised risk management cycle consisting of four interrelated components.

The four steps of the cycle, as defined in NIST SP 800-39, are:

1. **Frame: Definition of the context for risk-based decision-making (assumptions, constraints, risk tolerance).**
2. **Assess: Identification and estimation of risks (threats, vulnerabilities, impacts).**
3. **Respond: Taking measures to address the risk once it has been identified.**
4. **Monitor: Continuous verification of the effectiveness of the measures and changes in the environment.**

This process includes a feedback loop for the continuous improvement of activities.

3.4 Risk Assessment Methodology

3.4.1 Assessment Approach

NIST SP 800-30 Rev.1 explicitly states that risk and its contributing factors can be assessed in a variety of ways. The standard distinguishes three main assessment approaches, allowing maximum flexibility:

1. **Quantitative Assessment:** Uses numbers where the significance and proportionality of the values are strictly maintained (e.g. monetary amounts or probability percentages).
 - o **Advantage:** Effectively supports cost-benefit analysis for the selection of measures.
 - o **Disadvantage:** Interpretation of the numbers is often required, while the rigour of the method is reduced when based on subjective estimates or uncertain data.
2. **Qualitative Assessment:** Uses non-numerical categories or levels (e.g. Very Low, Low, Moderate, High, Very High).
 - o **Advantage:** Facilitates the communication of results to decision-making executives.
 - o **Disadvantage:** The range of values is small, making relative ranking of risks difficult, while results may be subjective if clear definitions are absent.
3. **Semi-quantitative Assessment:** Uses scales or representative numbers (e.g. 0-10, 0-100) whose values do not necessarily correspond to real magnitudes but simply represent the relative relationship between levels.
 - o **Advantage:** Combines the benefits of the above two methods, allowing easier ranking compared to the qualitative method while providing greater detail.

The choice of approach (or combination thereof) depends on the organisational culture, particularly as regards its stance towards uncertainty and risk communication.

3.4.2 Methodology Flexibility

Although NIST SP 800-30 Rev.1 contains extremely detailed tables and scales, the text clarifies that the methodology is characterised by maximum flexibility. There are no specific requirements with regard to formality, rigour, methodologies or tools.

However, in contrast to ISO which leaves the organisation to create its own scales from scratch, NIST provides a complete, ready-to-use model in its Appendices (Appendices D-I).

- **Template Character:** These templates (threat tables, likelihood/impact scales) are explicitly characterised as 'exemplary' and 'tailorable'.
- **Customisation Capability:** Organisations are encouraged to use these templates as a starting point and adapt them to their own specific circumstances.
- **Non-Mandatory Use:** The use of the specific tables and templates provided in the document is not required in order to conduct the assessment.

In essence, NIST offers a 'ready-made solution' approach that is nevertheless open to modification, in contrast to ISO's approach. It acknowledges that a single risk model cannot meet the diverse needs of all organisations.

3.4.3 Risk Calculation Technique

The fundamental NIST equation defines risk as a function of two factors: (i) the likelihood of a threat event occurring and (ii) the adverse impact that would result if the event were to materialise.

For the calculation of the risk level, the standard provides detailed tables and scales:

1. Measurement Scales: NIST proposes the use of a 5-level scale for all factors (Threat, Vulnerability, Likelihood, Impact). The levels are: Very Low, Low, Moderate, High, Very High.

- In the Semi-quantitative approach, these levels are mapped to numerical scores (e.g. 0-100), allowing greater precision in ranking.

2. Risk Matrix: The calculation is typically performed through a table (matrix), as defined in Table I-2. Likelihood (rows) and Impact (columns) are combined there, producing a Level of Risk (e.g. High Likelihood + Moderate Impact = High Risk).

3. Calculation Flexibility: The standard recognises that risk may not simply be a single number, but a vector. This means risk can be represented by multiple values, where different types of impact are assessed separately.

Finally, NIST places great emphasis on recording uncertainty. The calculation must be accompanied by an estimate of the uncertainty arising from incomplete data or subjective judgements.

3.4.4 Threat/Vulnerability Catalogues

In contrast to the more general approach of other standards, NIST SP 800-30 Rev.1 provides extremely detailed and ready-to-use catalogues (taxonomies) in its appendices. The underlying strategy is one of 'tailoring': the organisation starts from a comprehensive list and removes what does not apply.

Specifically, the standard includes:

1. **Threat Source Taxonomy: Categorises sources into four main groups: (i) Adversarial, (ii) Accidental, (iii) Structural, and (iv) Environmental.**
2. **Threat Event Catalogue: Here NIST stands out by providing lists based on Tactics, Techniques and Procedures. It describes specific attack scenarios (e.g. Phishing, SQL Injection) with the level of detail needed for operational risk assessment.**
3. **Vulnerabilities and Predisposing Conditions: Provides vulnerability catalogues, but also introduces the concept of 'predisposing conditions'. These are conditions that exist in the environment and contribute to (increase or decrease) the likelihood that a threat event will result in adverse impacts.**

Implementation Strategy: The NIST strategy is one of 'tailoring'. The organisation is called upon to take these ready-made lists and remove what does not apply (e.g. if there is no adversary with specific capabilities), or to add new threat events specific to its environment.

3.5 Resources and Implementation

3.5.1 Implementation Complexity

The NIST methodology is characterised by high implementation complexity due to the extent, detail and interconnection of its documents. Its application is not limited to a single department, but requires the active engagement of all three tiers of the organisation.

Specifically:

- **Expertise Requirement:** The process cannot be performed by unskilled personnel. The participation of risk management professionals with specialised knowledge is required, as well as individuals with technical expertise at the systems level.
- **Process Complexity:** The need for coordination between three tiers (Organisation, Business Processes, Systems) and the requirement for bidirectional information flow increases the administrative complexity significantly.
- **Data Management:** The volume of data generated (threats, vulnerabilities, control results) is large and often requires automated tools for its management, especially at the information systems level.

However, the existence of ready-made templates (such as threat catalogues) reduces the time required for the initial design of the methodology, compared to ISO which requires design from scratch.

3.5.2 Required Resources (Implementation Cost)

The implementation of the NIST methodology requires significant resource investment, focused primarily on the commitment of human resources and the management of extensive documentation. Although the standards are available free of charge, their implementation involves significant time and human capital costs.

- a) Human Resources Commitment:** The process requires the participation of many different roles across all levels of the hierarchy. Time is required from top management (Heads of Agencies, Chief Executive Officers) for strategic decisions, from risk managers for the execution of the assessment, and from system operators for the collection of technical data.
- b) Documentation and Bureaucracy:** NIST imposes strict documentation requirements. Each step of the process must be recorded in detail. In particular, the assessment process generates extensive reports.
- c) Continuous Monitoring:** In contrast to a one-off assessment, NIST requires continuous monitoring. This permanently commits resources for compliance verification and the tracking of changes in the threat environment.

4. Comparative Evaluation and Conclusions

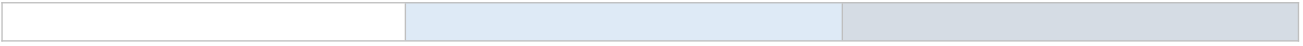
4.1 Consolidated Criteria Table

The following table presents the comparative overview of the ISO/IEC 27005:2022 standard and the NIST SP 800-30 Rev.1 and SP 800-39 guidelines, based on the four thematic axes defined in the methodology section.

Comparison Criteria	ISO 27005	NIST SP 800-30 rev.1 και SP 800-39
Identity and Origin		
Issuing Body	International Organisation for Standardisation (ISO) and IEC.	US National Institute of Standards and Technology (NIST)
Current Version	October 2022 (4th edition)	SP 800-39: March 2011 SP 800-30 Rev.1: September 2012
Legal Nature	Voluntary International Standard (Guidance)	Mandatory for US Federal Agencies; voluntary for private-sector organisations
Geographical Scope	Global (Worldwide standardisation)	Formally US, practically global with intent to harmonise with ISO
Access Cost	Paid (Copyright Protected).	Free (US Government Work — no copyright).
Scope and Architecture		
Focus Levels	Two levels: • Primary/Business Assets: business processes and information • Supporting Assets: IT infrastructure (Hardware, Software, Networks, Personnel) Business Processes διαδικασίες και πληροφορίες Supporting Assets: Hardware, Software, Networks, Personnel	Three Hierarchical Tiers: 1. Organisation (Tier 1) 2. Mission/Business Processes (Tier 2) 3. Information Systems (Tier 3)
Document Structure	Single guidance document	Modular structure (SP 800-39 for strategy SP 800-30 for assessment)
Management Cycle	6-Step Process (based on ISO 31000): Context establishment — Assessment — Treatment — Acceptance — Communication —	Iterative cycle of 4 interrelated steps: Frame — Assess — Respond — Monitor

	Monitoring 1. Context establishment 2. Assessment 3. Treatment 4. Acceptance 5. Communication 6. Monitoring Key feature: Executed in two cycles — Strategic and Operational	1. Iterative cycle of 4 interrelated steps: Frame — Assess — Respond — Monitor 2. Iterative cycle of 4 interrelated steps: Frame — Assess — Respond — Monitor 3. Iterative cycle of 4 interrelated steps: Frame — Assess — Respond — Monitor 4. Iterative cycle of 4 interrelated steps: Frame — Assess — Respond — Monitor
Risk Assessment Methodology		
Assessment Approach	Event-based: Strategic scenarios ή Asset-based: Operational scenarios (detailed)	Three Assessment Approaches: • Qualitative • Quantitative • Semi-quantitative 1. Qualitative 2. Quantitative 3. Semi-quantitative
Methodology Flexibility	Functions as a non-prescriptive standard, allowing each organisation to choose its own approach (Qualitative / Quantitative / Semi-quantitative). Provides indicative templates.	Offers a 'ready-made solution' approach, providing complete templates as a starting point with recommended 5-level scales. Templates are tailorable.
Risk Calculation	Freely defined. Typically: Likelihood × Consequence, with optional Asset Value inclusion. Non-linear calculations permitted.	Uses a risk matrix with pre-defined 5-level scales (Very Low – Very High). Results can be a single value or a vector. Uncertainty recording required.
Threat/Vulnerability Lists	Indicative catalogues of typical threats (Table A.10) and vulnerabilities (Table A.11) as guidance. Not exhaustive; fully customisable.	Event lists based on Tactics, Techniques and Procedures (Adversarial, Accidental, Structural, Environmental). Tailoring strategy: start from the complete list and remove

		inapplicable items.
Resources and Implementation		
Implementation Complexity	High effort in framework establishment. Due to the absence of ready-made solutions, the organisation must design the entire methodology from scratch, committing specialised personnel.	High administrative and structural Complexity. Απαιτεί συντονισμό 3 επιπέδων και εμπλοκή εξειδικευμένων ρόλων. Για τη διαχείριση μεγάλου όγκου δεδομένων συστήνονται αυτοματοποιημένα Tools. Ύπαρξη έτοιμων προτύπων για ταχύτερο, αρχικό σχεδιασμό
Resource Requirements	Mainly operational costs: • Coordination with budget cycles • Commitment of specialised personnel for interviews and team assessments • Continuous communication and consultation • Extensive documentation • Mainly operational costs: • Coordination with budget cycles • Commitment of specialised personnel for interviews and team assessments • Continuous communication and consultation • Extensive documentation • Mainly operational costs: • Coordination with budget cycles • Commitment of specialised personnel for interviews and team assessments • Continuous communication and consultation • Extensive documentation	High operational costs: • Commitment of specialised roles across all 3 tiers • Permanent resources for continuous monitoring • Extensive documentation at every step • High operational costs: • Commitment of specialised roles across all 3 tiers • Permanent resources for continuous monitoring • Extensive documentation at every step • High operational costs: • Commitment of specialised roles across all 3 tiers • Permanent resources for continuous monitoring • Extensive documentation at every step • High operational costs: • Commitment of specialised roles across all 3 tiers • Permanent resources for continuous monitoring • Extensive documentation at every step



4.2 Conclusions of the Theoretical Comparison

The comparative overview of the two frameworks reveals that the choice between the ISO 27005 standard and the NIST SP 800 guidelines series is not simply a technical dilemma, but a strategic decision that reflects the organisation's priorities, culture and operational context.

ISO 27005, functioning as a high-level guide, offers the organisation the freedom to design the methodology from scratch, connecting assets to business objectives in a business-centric approach. Its non-prescriptive character makes it more flexible but also more demanding in terms of the expertise required for its implementation.

Beyond the structure, the difference in the depth of technical analysis is also notable. While ISO focuses more on strategic alignment and the connection with financial cycles, NIST delves into the technical detail of the assessment process, providing ready-made taxonomies of threats and vulnerabilities and specific calculation methods.

In conclusion, the two standards should not be treated as mutually exclusive, but often as complementary. In practice, an organisation may seek ISO 27001 certification for international recognition while using NIST SP 800-30 for the technical execution of its risk assessments, leveraging the detailed appendices of the latter.

5. Presentation of Software Tools

5.1 Introduction

Before the technical presentation and evaluation of the specialised software tools (GRC Tools), it is deemed appropriate to capture the practical market reality. In the context of this study, an informal survey was conducted among professionals in the information security sector.

Specifically, it was noted that the adoption of specialised risk management platforms is not the norm for the majority of businesses. With the exception of large multinational organisations or those operating in strictly regulated sectors (such as finance and healthcare), the reality is quite different.

1. **Extensive use of Microsoft Excel: The dominant trend in small and medium-sized enterprises is the use of general-purpose software, primarily Microsoft Excel. These organisations rely on customised spreadsheets to record risks, calculate likelihood and impact, and track treatment plans.**
2. **Outsourcing: In parallel, it is often observed that security audits are outsourced to external partners. Through this practice, companies avoid the complexity of implementing an internal risk management process.**

Under this lens, the examination of the tools (SimpleRisk, MONARC, Verinice, EAR/PILAR) that follows is carried out based on a new, distinct evaluation framework. The goal of this section is to evaluate each tool along three distinct axes:

1. Technical Identity and Licensing:

The first axis concerns the availability and technical requirements of the application — factors decisive for the viability of the solution in an organisation:

- **Licensing Model:** It is examined whether the software is Open Source, Commercial or offers a free version with restrictions (Trial/Freemium).
- **Free Availability Scope:** An assessment is made of whether the free version is full-featured, a trial (Beta/Demo) or time-limited, and whether it allows productive use without hidden costs.
- **Architecture and Requirements:** Distinction between web-based applications (which favour multi-user collaboration) and standalone desktop applications. Platform compatibility (Windows, Linux, macOS) is also examined.

2. Risk Management Functionality:

The second axis examines the essence of the process, i.e. the extent to which the tool can support a comprehensive risk study:

- **Asset Management:** The ability to mass-import, categorise and value the organisation's assets.
- **Pre-installed Libraries:** Possibly the most critical functionality criterion. It is examined whether the tool provides ready-made catalogues of threats, vulnerabilities and security controls (based on ISO 27001/27002 or NIST).
- **Calculation Mechanism:** The ability to configure the way risk is calculated (e.g. creating a custom Risk Matrix) so as to match the organisation's methodology.
- **Reports:** The ability to export dashboards and final reports (in PDF/Excel format) for presentation to management.

3. User Experience:

- **Interface:** The ergonomics, ease of navigation and learning curve of the tool are evaluated, as an unfriendly environment is often a deterrent factor for adoption.

5.2 Tools

5.2.1 SimpleRisk

5.2.1.1 Technical Identity and Licensing

This section analyses the technical characteristics and the distribution framework of SimpleRisk — factors that determine the accessibility and usability of the tool for an organisation.

- **Licensing Model:** SimpleRisk follows the 'Freemium' model. The basic installation of the tool (SimpleRisk Core) is available free of charge from the company's website, allowing the user to install and use it without a licence fee.
- **Free Availability Scope:** During the process of downloading the software for local installation, a significant accessibility restriction was found. The manufacturing company applies a strict lead-capture policy, requiring the submission of corporate contact details before granting download access.

Evaluation and Testing Options: For users who wish to evaluate the software before proceeding with installation or purchase, the company provides three distinct options with different levels of access and immediacy.

1. **30-day Free Trial:** This is a fully hosted version that includes all the paid features. However, this option is available strictly for corporate/business accounts.
2. **Live Demonstration:** This concerns a live demonstration of the tool's capabilities by a company representative. This option is not on-demand, as it requires the interested party to submit a request and schedule the presentation.
3. **SimpleRisk Sandbox:** This is the option used for the purposes of this study. It is an online simulation of the application's full functionality. Through the Sandbox, all the

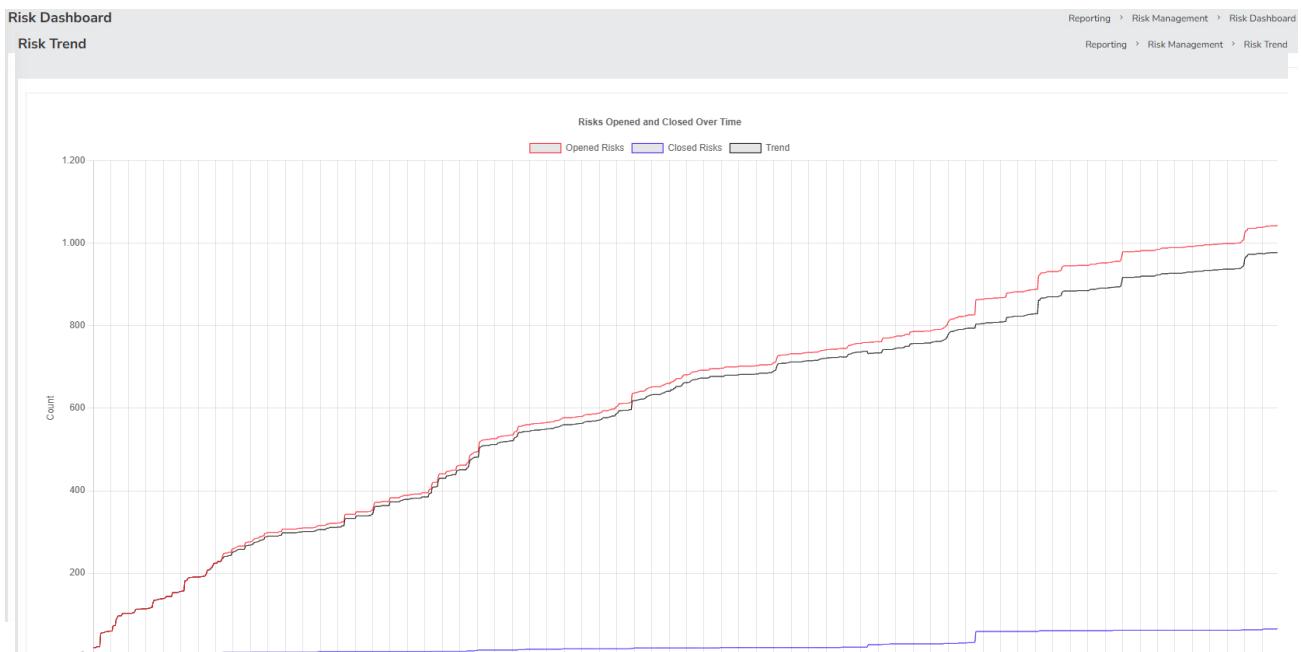
capabilities of the paid version were examined in a controlled environment without requiring any licence commitment.

- **Architecture and Requirements:** SimpleRisk is a web-based application, allowing simultaneous access by multiple users via browser. The system requirements are particularly low.

5.2.1.2 Risk Management Functionality

Through the examination of the simulation environment (Sandbox), the completeness of the tool was evaluated on the four main functionality axes:

- **Asset Management:** The tool has powerful mechanisms for asset inventory and valuation. As reflected in the 'Manage Assets' option, each asset can be assigned a value and classified according to user-defined categories.
- **Pre-installed Libraries:** The software provides ready-made libraries covering international standards. In the 'Define Control Frameworks' screen, active frameworks such as ISO 27001 were identified.
- **Calculation Mechanism:** The platform supports dynamic risk calculation and monitoring of risk evolution. In the 'Plan Mitigation' screen, both the Inherent Risk (before measures) and the Residual Risk (after their implementation) are displayed distinctly.
- **Reports:** The ability to export conclusions is enhanced by advanced visualisation tools. The 'Risk Dashboard' provides pie charts for the distribution of risks by level (High, Medium, Low) and status.



5.2.1.3 User Experience

The interface of SimpleRisk is distinguished by its modern and refined aesthetics, which differ significantly from the cold appearance of traditional spreadsheets. The application strikes a balance between functionality and ease of use.

5.2.2 Monarc

MONARC (Method for an Optimised Analysis of Risks by CASES) is a special case in the GRC tools space, as it does not originate from a private software company but was developed with the strategic support of the Grand Duchy of Luxembourg's national cybersecurity agency (CASES/SECIN).

5.2.2.1 Technical Identity and Licensing

- **Licensing Model:** The software is strictly open source and is distributed under the GNU Affero General Public License version 3 (AGPLv3). The choice of this licence is a strategic decision that ensures that any organisation using or modifying the code must also publish its changes.
- **Free Availability Scope:** Due to the nature of the project, there is no distinction between a free and a commercial version. The user has access to all the tool's capabilities without any financial restriction.
 1. **Pre-installed Virtual Machine (OVA):** For immediate testing without complex configuration, via simulation software (e.g. VirtualBox).
 2. **Docker Containers:** The recommended method for production operation, which offers ease of management and upgrades.
 3. **Source Code Download:** Possibility of manual installation directly from GitHub for specialised configurations.

- **Architecture and Requirements:** MONARC is a purely web-based application, designed for collaborative use. Technically, the backend is developed in Python (Django framework) and the frontend in JavaScript.

5.2.2.2 Risk Management Functionality

The heart of MONARC is the structured risk analysis process, which faithfully follows the ISO/IEC 27005 methodology. The tool guides the user through a hierarchical approach, allowing analysis at different levels of detail.

- **Asset Management:** Asset management in MONARC is implemented through a dynamic tree structure (Asset Tree). The system clearly distinguishes between asset types:
 - **Primary Assets:** Include the business processes and information that have direct value for the organisation. Here the impacts (on Confidentiality, Integrity and Availability) in the event of a breach are defined.
 - **Supporting Assets:** Include hardware, software, networks and human resources. These elements 'inherit' value from the primary assets and constitute the objects of threat analysis.
- **Pre-installed Libraries:** One of MONARC's most powerful features is the built-in 'Knowledge Base'. The tool does not require the user to enter data from scratch, but provides a comprehensive library of ready-made objects.
 - **Standard Objects (Object Libraries):** Ready-made asset categories (e.g. Servers, Laptops) with pre-defined properties.
 - **Threat and Vulnerability Catalogues:** Each asset type is automatically linked to relevant threats and vulnerabilities, based on standards such as ISO 27005 and the specifications of the CASES organisation. This significantly reduces the time required for analysis.

Asset import center

Import method:

☐ By duplicating
 ☒ By merging

Only global assets can be imported by merge.

List of common MONARC assets

Q Search an asset...

Name	Category	Asset type	Actions
Front Office	Model Structure	Container	
Specific software	Software	Software	
Specific software maintenance	Software	Software maintenance	
User workstations	Equipment	Desktop computer	

1. Table of available assets in the MONARC common Library.
2. **Action:** Initiate the import procedure for the corresponding asset.

- **Calculation Mechanism:** The risk calculation in MONARC is semi-quantitative and table-based (Risk Matrices). The process follows these steps:

1. **Impact Assessment:** The impact on the primary assets is defined on a scale (usually 0-4) for the CIA parameters (Confidentiality, Integrity, Availability).
2. **Likelihood Estimation:** The likelihood of the threat occurring on the supporting assets is calculated.
3. **Risk Calculation:** The tool automatically calculates the Inherent Risk by multiplying impact by likelihood. Then, taking into account the existing security measures, it calculates the Residual Risk.

33

Search an asset...

MyPrint [EN]

- + IoT
- Printing department
 - Printing operators
 - Back Office Rotary printing press
 - System administrator
 - Building
 - Network and Telecom
 - Rotary printing press
- Computer graphics department
 - Front Office
 - Back Office
- + GDPR legal obligations

Information risks 1

Operational risks 2

74 information risks

Risk threshold (on max CIA) ☒ ☐ ☐ ☐ ☐ Keywords

Asset	Impact			Threat		Vulnerability	
	C	I	A	Label	Prob.	Label	Existing c
Printing operators	1	2	3	Error in use	3	Users are not made aware of information security	The person in place doe He is retiring soon.
Printing operators	1	2	3	Error in use	3	No IT charter specifying the rules of use	No charter in place.

1. The information risk table is based on CIA^[1] criteria.
2. The operational risk table is based on ROLFP^[2] (see [Operational Risks](#))

Depending on your selection, the display risk table may change:

Selection	Information Risks	Operational Risks
Root of analysis	All risks of analysis	All risks of analysis
Primary Asset	Risks associated with its supporting assets	Risks associated with themselves
Supporting Asset	Risks associated with themselves	No risks

- **Reports:** MONARC's report generation system is designed to cover both technical and administrative requirements. Through the 'Dashboard' and the export menu, the user can generate:
 - **Risk Table:** A detailed visualisation of all risks, ranked by criticality.
 - **Risk Treatment Plan:** A report including the proposed measures, those responsible for implementation and the timeline.
 - **Statement of Applicability:** The tool automatically generates the SoA document, which is a prerequisite for ISO 27001 certification. This function is based on the dynamic link between the risks and the controls of the ISO 27001 Annex A.

5.2.2.3 User Experience

It is noted that the evaluation of this section was based on the study of user manuals, as technical constraints did not allow the execution of the software in a simulation environment (VMware or Docker on the available system).

5.2.3 Verinice

5.2.3.1 Technical Identity and Licensing

Verinice is one of the most recognised European GRC solutions, with a strong base in Germany and emphasis on ISO 27001 and BSI IT-Grundschutz standards. BSI IT-Grundschutz is the German federal standard for information security, developed by the Federal Office for Information Security (BSI).

- **Licensing Model:** Officially, the source code is freely available, allowing free inspection. However, the company charges for the provision of the ready-to-use, executable program through a subscription or perpetual licence model.
- **Free Availability Scope:** For evaluation and training purposes, the verinice.EVAL edition is available. This is a version which, although it provides full functionality for creating a security concept, has certain limitations (e.g. it does not allow the generation of comprehensive reports or import of large datasets).
- **Architecture and Requirements:** The tool is in a phase of technological transition, offering two distinct architectural approaches.
 1. **Verinice.Client (Desktop):** This constitutes the stable and widely used version of the software (the one installed for testing). It is compatible with Windows, macOS and Linux operating systems.
 2. **Verinice.veo (Web-based Install on Linux Server. Requirements: Low (2 vCPU, 2 GB RAM). Multi-user via browser.):** This is the new generation of the tool, which is purely web-based (cloud-native) and allows use via browser. However, this version is promoted primarily for commercial use.

5.2.3.2 Risk Management Functionality

The functional approach of Verinice focuses on strict standardisation and hierarchical modelling, offering specialised tools for each stage of the risk management lifecycle.

- **Asset Management:** In contrast to simple record-keeping lists, Verinice adopts a hierarchical tree structure for the representation of assets. Furthermore, it supports automatic dependency management: if a supporting asset is linked to a primary asset, the vulnerability assessment is propagated.
- **Pre-installed Libraries:** This is the most significant advantage of the tool. On start-up, Verinice does not require the user to enter data from scratch, but provides ready-made catalogues of security objects and best practices, covering both ISO 27001/27002 and BSI IT-Grundschutz.
- **Calculation Mechanism:** The risk analysis process is standardised and explicitly based on ISO/IEC 27005. Through the special function 'Run ISO/IEC 27005 Risk Analysis', the tool automatically guides the user through the risk identification, assessment and treatment process.
- **Reports:** In this area, the most significant distinction between editions is found. While the platform has the capability of producing rich reports (such as a risk treatment plan, executive summary and Statement of Applicability), this function is severely restricted in the evaluation version.

5.2.3.3 User Experience

The user experience of Verinice is characterised by a marked contrast between the content and the complexity of the interface, which is judged as the software's weakest point. The graphical environment is characterised by an overly complex, technical approach that requires significant familiarisation time from the user.

5.2.4 EAR/PILAR

The EAR/PILAR tool suite is the standardised software solution widely used in the Spanish Public Administration for risk management. It is developed with the strategic support of the Spanish National Cryptologic Centre (CCN) and implements the MAGERIT risk methodology — the official Spanish risk management standard.

- **µPILAR:** Intended for small systems following a homogeneous security approach, offering rapid analysis.
- **PILAR Basic:** Aimed at users who need a standard risk analysis. Provides organisational capabilities in security domains and supports the use of security measures.
- **PILAR RM (Risk Management):** The full version for risk management. Allows detailed configuration (e.g. threat management, profile creation) and supports multiple user levels.
- **PILAR BCM (Business Continuity Management):** A specialised edition for Business Continuity Management. Focuses on the calculation of recovery objectives (RTO - Recovery Time Objective) and recovery points (RPO - Recovery Point Objective).

5.2.4.1 Technical Identity and Licensing

The EAR/PILAR application family follows a unified technical and commercial approach across all its editions (µPILAR, Basic, RM, BCM). Although each edition targets a different size of organisation, the licensing policy and technical architecture are shared.

- **Licensing Model:** The software is proprietary and commercial. Licensing is flexible and offers two distinct acquisition methods, which apply to all editions of the application:
 - o **As a Service (annual subscription):** Concerns annual rental of the usage licence. The advantage is the lower initial cost and the inclusion of all upgrades released within the year.

tool	size S	size M	size L
number of users	1	5	10
µPILAR	100 €	200 €	400 €
PILAR Basic	200 €	400 €	800 €
PILAR BCM	350 €	700 €	1,400 €
PILAR RM	500 €	1,000 €	2,000 €
PILAR RM + BCM	700 €	1,400 €	2,800 €

PILAR + BBDD	+30%	+30%	+30%
RMAT	750 €	1,500 €	3,000 €

**Concerns the annual rental of the usage licence with all new versions.*

- o **As a Product (one-time purchase):** Concerns the purchase of a permanent usage licence for the specific version. The user pays once and owns the software permanently. However, future upgrades require additional payment.

tool	size S	size M	size L
number of users	1	5	10
µPILAR	250 €	500 €	1,000 €
PILAR Basic	500 €	1,000 €	2,000 €
PILAR BCM	1,000 €	2,000 €	4,000 €
PILAR RM	1,500 €	3,000 €	6,000 €
PILAR RM + BCM	2,000 €	4,000 €	8,000 €
PILAR + BBDD	+30%	+30%	+30%
RMAT	2,250 €	4,500 €	9,000 €

**Holders of a previous version wishing to upgrade to the current one are entitled to an 80% discount on the original product price. Optionally, with an annual cost equal to 20% of the purchase value, maintenance and all intermediate upgrades within the year are provided.*

Important notes:

- **PILAR + BBDD:** Additional function for the RM edition that allows data storage in a database for collaborative work by large teams.
 - **RMAT:** A separate configuration tool that allows specialised users to create customised threat and security measure libraries.
- **Free Availability Scope:** The free availability policy is common to the entire PILAR family and is divided into two levels of use:
 - o **Viewer mode (Free):** Anyone can use the software for free to open and read analysis files, but without the right to modify them.

- **Evaluation mode:** Full testing for 30 days is available. However, all manuals (µPILAR, Basic, RM) explicitly note that this version has specific functional restrictions:
 1. Does not allow the generation of reports.
 2. Calculates only a limited number of risks.
- **Architecture and Requirements:** The technical base is common to all variants, as they all use the Java programming language. This gives the application specific characteristics across all its editions.
 - **Software Requirements:** The only strict requirement mentioned is the Java Runtime Environment (JRE), version 8 or later. No specific operating system is required, as the application executes on any platform that supports JRE.
 - **Application:** The application's architecture is designed to operate without a classical installation. The user simply extracts the folder and runs the file (executable .exe or .jar), which is a significant advantage for portability.
 - **Data Management:**
 - The µPILAR and Basic editions work with local files (.mgr), storing data at the file system level.
 - The RM edition is the only one that differs architecturally at this point, as it additionally offers the possibility of connecting to a database for managing large volumes of data.

5.2.4.2 Risk Management Functionality

- **Asset Management:** The basis of the MAGERIT methodology is the identification and prioritisation of elements that have value for the organisation. PILAR Basic implements this process through an interactive tree structure.
 - **Identification:** The user is called upon to create the asset tree, distinguishing between primary assets (information and services).
 - **Supporting assets (such as hardware, software, communications):** The system automatically recognises dependencies, transferring security requirements from the primary to the supporting elements.

The user assigns a score of importance to each asset (scale 0-10), thereby determining the level of protection required.

- **Pre-installed Libraries:** One of PILAR Basic's most significant advantages is that it relieves the user of the need to create threat or measure lists from scratch. The application comes with a comprehensive, pre-loaded knowledge base.
 - **Security Profiles:** The tool provides ready-made sets of security measures based on international standards (such as ISO 27002) or security levels (e.g. Low, Medium, High). The user selects the desired profile and the system suggests the relevant measures.
 - **Threat Catalogues:** Based on the type of asset, the system automatically proposes the relevant threats from the standard MAGERIT library, as well as the typical likelihood of their occurrence.
- **Calculation Mechanism:** The risk calculation in PILAR Basic is dynamic and takes place in real time as the user enters data. The mechanism operates by comparing:
 - **Current state:** Calculates the risk based on the measures already implemented in the organisation.
 - **Target:** Calculates the projected risk once the proposed measures are implemented.

The result is visualised and immediately shows whether the risk exceeds the acceptable threshold, taking into account the likelihood of the threat and the impact on the asset.

- **Reports:** The final phase of the functionality, as described in the application menu, is the production of documentation. PILAR Basic has a built-in report generation engine that exports the results in an organised format.

1. Executive Summary (for management).
2. Detailed Technical Report.
3. Statement of Applicability.
4. Risk Treatment Plan.

5.2.4.3 User Experience

The user experience in PILAR Basic falls short of modern design standards (Modern UI). The working environment does not have a modern aesthetic, but is reminiscent of older, classic software, with a multi-panel interface that is more complex to manage.

5.3 Comparative Evaluation and Conclusions

The following table presents the comparative overview of the four software tools (SimpleRisk, MONARC, Verinice, EAR/PILAR), based on the technical and functional criteria defined in the introduction of this section.

Comparison Criteria	SimpleRisk	MONARC	Verinice	EAR/PILAR (Basic)
Technical Identity and Licensing				
Licensing Model	The core is open-source and free. What You Pay For: The additional paid Modules (plugins). What You Pay For: The additional Modules (plugins) that sit on top of the core.	All code and the application are free. What You Pay For: Nothing. There is no commercial software component.	The code is open-source, but the ready-to-use executable is charged. What You Pay For: The ready-to-use application and updates.	The code is closed and proprietary. What You Pay For: The usage licence from the outset in order to run the program.
Free Availability Scope	Free (Core) Costs apply only for Extras (price on request). Free tool restriction: Requires a corporate email address to download.	Free Free No acquisition or subscription cost. Full access to all features. Ideal for public bodies and SMEs. Full access to all features without any restriction.	~714 €/έτος Subscription costs €714.00 (1 year) or €1,285.20 (2 years). Free tool restriction: Does not allow saving or exporting reports.	Varies (€100–€8,000)/year Prices vary by edition and licence type (Rental/Purchase). Free tool restriction (Trial): 30-day trial without the ability to print or export.
Architecture and Requirements	Web-based Installation on Linux Server.	Web-based Installation on Docker/VM.	Desktop Eclipse RCP-based application.	Desktop Standalone application (no install needed).

	Requirements: Low (2 vCPU, 2 GB RAM). Access via Browser.	Requirements: Moderate (4 GB RAM for VM). Access via Browser.	Requirements: Runs locally on all OS. Moderate requirements (4 GB RAM).	Requirements: Very low. Requires only Java Runtime Environment (JRE 8+).
Risk Management Functionality				
Asset Management	Lists and IP Scanning Flat list recording. No tree structure with folders and sub-folders. Key feature: Automation via scanning for rapid device discovery (speed).	Inheritance Tree Dynamic tree structure. Clear distinction between Primary and Supporting assets. Key feature: Impact inheritance from services to equipment. Δυναμική δένδρική δομή. Γίνεται διαχωρισμός των περιουσιακών στοιχείων που κινδυνεύουν και δεν κινδυνεύουν και εστιάζουμε στην πρώτη περίπτωση. Key feature: Value and impacts are automatically 'inherited' from services to equipment.	Inventory Tree Hierarchical infrastructure representation. Key feature: Focus on bulk entry and automatic dependency management. Hierarchical infrastructure representation. Key feature: Focus on bulk import from IT inventory tools.	Dependency Structure (MAGERIT) Strict Essential/Support distinction. Key feature: Automatic dependency calculation and value propagation. Strict Essential/Support distinction. Key feature: Automatic dependency correlation between levels. Impact calculation.
Pre-installed Libraries	Includes mappings for compliance with: NIST, ISO, PCI DSS, HIPAA	Object and threat library based on: ISO 27005 and CASES ISO 27005 και CASES	Full catalogue integration: BSI IT-Grundschutz, ISO 27001, VDA	Ready-made measure and threat packages based on: MAGERIT and ISO 27002 MAGERIT και ISO 27002
Calculation Mechanism	Configurable Calculates Inherent Risk (without measures) and Residual Risk (with measures). Feature: Fully customisable Risk Matrix. Calculates Inherent Risk (without measures) and Residual Risk (with measures). Feature:	Semi-quantitative Uses Impact × Likelihood tables. Feature: Impact is automatically 'inherited' from the business process to the technical equipment, saving time.	Standardised (ISO 27005) Performs strict analysis based on ISO 27005. Feature: Automatic risk level derivation from threat/vulnerability/impact combination. Performs strict analysis based on ISO 27005. Feature:	Dynamic (Real-time) Calculates current and target state in real time. Feature: Risk is recalculated in real time according to the effectiveness percentage of the measures.

	Allows the creation of custom mathematical formulas for score calculation.		Automatically correlates: Threat → Vulnerability → Measure → Risk, as defined by ISO.	
References	Provides overview Dashboards and trend charts (Risk Trends) for immediate visual updates. Full export of detailed reports typically requires the purchase of additional modules.	Automatically generates the Statement of Applicability, risk tables and Risk Treatment Plan. Offers free export of all data in PDF and Excel formats.	The free edition does not allow any report generation or export. The full (paid) version offers rich reporting including Risk Treatment Plan and Executive Summary. The full commercial edition provides all reports in editable formats (Word, Excel, PDF).	The Trial edition does not allow printing or file export. The full commercial edition provides specialised reports (Executive and Technical) for each management level.
User Experience	Modern Environment Modern graphics and dashboards. Learning: Navigation is intuitive, though the module system requires initial familiarisation. Features modern graphics and dashboards. Learning: Navigation is pleasant, although the menus are information-dense initially.	Intuitive Navigation Drag-and-drop and tree-structure organisation. Learning: Low learning curve. The 'Knowledge Base' significantly reduces setup time. Organisation with drag-and-drop functions and tree structure. Learning: Smooth, as the environment guides the user through the process.	Complex Environment Multi-window, multi-tab environment (legacy technology). Learning: Steep learning curve. Documentation-heavy; requires training. Multi-window, multi-tab environment (legacy technology). Learning: Steep (Difficult). Requires significant familiarisation time.	Minimal and Rigorous Simple design without graphic elements; industrial profile. Learning: Requires training in the methodology to understand the workflow.

Conclusions

The comparative overview of the four software tools (SimpleRisk, MONARC, Verinice, EAR/PILAR) reveals a significant heterogeneity in the GRC systems market. Although all tools serve the same fundamental need — the systematic management of information security risk — they differ markedly in their philosophical approach, technical architecture and target audience.

In terms of licensing and cost, MONARC stands out as the only solution that offers all its capabilities at no cost, making it ideal for organisations with a limited budget or those wishing to explore the field without financial commitment.

As regards the methodological approach, a gradation from simplicity to rigour is observed:

- SimpleRisk focuses on speed and oversight, using flat lists and scanning automations, but at the cost of structural detail.
- MONARC introduces the innovation of 'inheritance', offering a balanced approach that reduces the workload through the intelligent transfer of impacts from services to equipment.
- Verinice operates as a compliance tool, based on strict standards (ISO/BSI) and inventory trees, ideal for audits but rigid in use.
- EAR/PILAR offers the greatest analytical depth with the MAGERIT methodology, dynamically calculating risk and dependencies, but is aimed primarily at specialised analysts.

Finally, the user experience confirms the gap between modern web-based applications and traditional desktop applications. Web-based Install on Linux Server. Requirements: Low (2 vCPU, 2 GB RAM). Multi-user via browser. solutions (SimpleRisk, MONARC) offer modern, collaborative and intuitive interfaces, while desktop tools (Verinice, PILAR) demand a steeper learning curve.

- For organisations seeking a comprehensive, free and collaborative solution, MONARC is the optimal choice.
- For those who prioritise visualisation and ease of use, SimpleRisk offers the best oversight.
- For requirements of strict compliance with European standards (BSI/ISO), Verinice is the definitive choice.
- For environments requiring mathematical precision and dynamic analysis of complex dependencies, EAR/PILAR is the technically most powerful tool.

6. Bibliography

ISO 27005

[1]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", σελ. 5

- [2]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity.", σελ. 5
- [3]: "This document was prepared by Joint Technical Committee ISO/IEC JTC 1, Information technology, Subcommittee SC 27, Information security, cybersecurity and privacy protection.", σελ. 5
- [4]: "This fourth edition cancels and replaces the third edition (ISO/IEC 27005:2018), which has been technically revised.", σελ. 5
- [5]: Δραστηριότητες | ΕΛΟΤ - Ελληνικός Οργανισμός Τυποποίησης.
<https://elot.gr/drastiriotites-elot/>.
- [6]: "Fourth edition 2022-10", σελ. 1
- [7]: "all guidance text has been aligned with ISO/IEC 27001:2022, and ISO 31000:2018;", σελ. 5
- [8]: "the terminology has been aligned with the terminology in ISO 31000:2018;", σελ. 5
- [9]: "the structure of the clauses has been adjusted to the layout of ISO/IEC 27001:2022;", σελ. 5
- [10]: "For an explanation of the voluntary nature of standards... see www.iso.org/iso/foreword.html.", σελ. 5
- [11]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization."
- [12]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks; perform information security risk management activities...", σελ. 7
- [13]: "ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization.", σελ. 5
- [14]: "National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees...", σελ. 5
- [15]: "This document is applicable to all organizations, regardless of type, size or sector.", σελ. 7
- [16]: ΕΛΟΤ EN ISO/IEC 27005 | ΕΛΟΤ <https://eshop.elot.gr/product/106819>

- [17]: "Top management is accountable for managing risks and should lead and drive risk assessments, including: ensuring that the necessary resources are allocated to managing risk", σελ. 33
- [18]: "When making plans for routine risk assessments, organizations should take account of any calendar that applies to their general business processes and associated budget cycles. ... Funds are then granted (diminished or denied) later.", σελ. 31
- [19]: "Proactive methods... can be used to identify vulnerabilities depending on... available resources (e.g. allocated funds, available technology, persons with the expertise to conduct the test).", σελ. 57
- [20]: "This monitoring and review activity should address (but not be limited to): ... total cost of ownership; necessary resources.", σελ. 39
- [21]: "This document is applicable to all organizations, regardless of type, size or sector. ... An organization... can also be a subset of a legal entity (e.g. the IT department of a company).", σελ. 7, 9
- [22]: "risk: effect of uncertainty on objectives... In the context of information security management systems, information security risks can be expressed as effect of uncertainty on information security objectives.", σελ. 2
- [23]: "The risk assessment should help the organization make decisions about the management of the risks that affect the achievement of its objectives.", σελ. 10
- [24]: "The assets can be divided into two categories: primary/business assets... supporting assets (components of the information system on which one or several business assets are based).", σελ. 47
- [25]: "This document provides guidance on: implementation of the information security risk requirements specified in ISO/IEC 27001... essential references within the standards developed by ISO/IEC JTC 1/SC 27", σελ. 6
- [26]: "This document provides guidance to assist organizations to: fulfil the requirements of ISO/IEC 27001 concerning actions to address information security risks", σελ. 7
- [27]: "This document contains detailed guidance on risk management and supplements the guidance in ISO/IEC 27003.", σελ. 6
- [28]: "This document provides guidance on... implementation of risk management guidance in ISO 31000 in the context of information security.", σελ. 6

[29]: "Normative references... ISO/IEC 27000, Information technology — Security techniques — Information security management systems — Overview and vocabulary", σελ. 7

[30]: "As Figure 1 illustrates, the information security risk management process can be iterative for risk assessment and/or risk treatment activities.", σελ. 8

[31]: "This process is based on the general risk management process defined in ISO 31000.", σελ. 7

[32]: "strategic cycle, where business assets, risk sources and threats, target objectives or consequences to information security events are evolving from changes in the overall context of the organization.", σελ. 9

[33]: "operational cycle, where the above-mentioned elements serves as input information or changed criteria that will affect a risk assessment or assessment where the scenarios should be reviewed and updated.", σελ. 9

[34]: "The information security risk management process should be continually monitored, reviewed and improved as necessary.", σελ. 39

[35]: "ISO/IEC 27001 does not mandate a particular approach... ensure that repeated information security risk assessments produce consistent, valid and comparable results.", σελ. 16

[36]: "Nevertheless, there are two main approaches for assessment: an event-based approach and an asset-based approach.", σελ. 16

[37]: "Event-based approach: identify strategic scenarios through a consideration of risk sources, and how they use or impact interested parties to reach those risk's desired objective.", σελ. 17

[38]: "An event-based approach can establish high level or strategic scenarios without spending a considerable amount of time in identification of assets on a detailed level... Events and consequences can often be determined by a discovery of the concerns of top management", σελ. 17

[39]: "Asset-based approach: identify operational scenarios, which are detailed in terms of assets, threats and vulnerabilities.", σελ. 17

[40]: "With an asset-based approach, the underlying concept is that risks can be identified and assessed through an inspection of assets, threats and vulnerabilities. An asset is anything that has value to the organization and therefore requires protection.", σελ. 17

- [41]: "The asset-based approach can identify asset-specific threats and vulnerabilities and allows the organization to determine specific risk treatment on a detailed level.", σελ. 18
- [42]: "Identifying the contributory risk sources using an event-based assessment typically requires drilling down from the general level of the scenario to the detail level", σελ. 24
- [43]: "but an asset-based assessment typically searches upwards from the asset to the scenario, in order to provide visibility regarding how consequences accumulate.", σελ. 24
- [44]: "ISO/IEC 27001 does not mandate a particular approach to be used to fulfil the requirements in ISO/IEC 27001:2022, 6.1.2.", σελ. 16
- [45]: "Techniques for risk analysis based on consequences and likelihood can be: a) qualitative... b) quantitative... c) semiquantitative", σελ. 19
- [46]: "The categories and values used in Table A.2 and Table A.4 are only examples. The most appropriate value to assign to each level of likelihood depends on the risk profile and risk appetite of the organization.", σελ. 42
- [47]: "No single organization is likely to encounter the range of risk represented by the entirety of these example scales. The context of the organization... should be used to define realistic upper and lower limits", σελ. 45
- [48]: "The level of risk can be determined in many possible ways. It is commonly determined as a combination of the assessed likelihood and the assessed consequences for all relevant risk scenarios.", σελ. 22
- [49]: "Alternative calculations can include an asset value as well as likelihood and consequence.", σελ. 22
- [50]: "In addition, the calculation is not necessarily linear, e.g. it can be likelihood squared combined with consequence.", σελ. 22
- [51]: "In any case the level of risk should be determined using the criteria established as described in 6.4.3.4.", σελ. 22
- [52]: "Table A.10 gives examples of typical threats. The list can be used during the threat assessment process.", σελ. 53
- [53]: "Threats considered as risk sources can be deliberate, accidental or environmental (natural)... The list indicates for each threat type where D (deliberate), A (accidental), E (environmental) is relevant.", σελ. 53

[54]: "Table A.11 gives examples for vulnerabilities in various security areas, including examples of threats that can exploit these vulnerabilities.", σελ. 55

[55]: "The lists can provide help during the assessment of threats and vulnerabilities... In some cases, other threats can exploit these vulnerabilities as well.", σελ. 54

[56]: "Context establishment means assembling the internal and external context for information security risk management", σελ. 8

[57]: "ISO/IEC 27001 specifies requirements for an organization to establish and maintain information security risk criteria that include: a) the risk acceptance criteria; b) criteria for performing information security risk assessments.", σελ. 11

[58]: "It means the chosen method should ensure the following properties of results: consistency... comparability... validity", σελ. 16

[59]: "This can involve... involvement of expertise in the relevant field, or other ways to collect the information required", σελ. 8-9

[60]: "Particularly where the qualitative approach is adopted, risk analysts should undergo training and periodic practice against an anchoring reference scale to maintain the calibration of their judgement.", σελ. 41

[61]: "Top management is accountable for managing risks... ensuring that the necessary resources are allocated to managing risk", σελ. 33

[62]: "Interviews with top management and those people in the organization who have a responsibility for a business process can assist in identifying not only the relevant events", σελ. 17

[63]: "To increase the reliability of estimating likelihood, organizations should consider using: a) team assessments rather than individual assessments", σελ. 21

[64]: "The risk communication and consultation activity should be performed continually.", σελ. 34

[65]: "When making plans for routine risk assessments, organizations should take account of... associated budget cycles... This monitoring and review activity should address... total cost of ownership", σελ. 31, 39

[66]: "ISO/IEC 27001 specifies requirements for organizations to retain documented information concerning the risk assessment process... and results", σελ. 35

[67]: "Documented information... should contain: a) a definition of the risk criteria... b) the identity of the risk owner(s)... Documented information about the information security risk treatment process should contain descriptions of... how risk treatment plans are produced", σελ. 35-36

NIST

[68]: "NIST Special Publication 800-39 is the flagship document... The purpose... is to provide guidance for an integrated, organization-wide program for managing information security risk", NIST SP 800-39, σελ. 3

[69]: "The purpose of Special Publication 800-30 is to provide guidance for conducting risk assessments... amplifying the guidance in Special Publication 800-39.", NIST SP 800-30, σελ. 2

[70]: "Special Publication 800-30 is being revised to provide guidance on risk assessment as a supporting document to Special Publication 800-39.", NIST SP 800-39, σελ. 4

[71]: "National Institute of Standards and Technology U.S. Department of Commerce", NIST SP 800-39, σελ. 1 & NIST SP 800-30 Rev.1, σελ. 1

[72]: "This publication has been developed by NIST to further its statutory responsibilities under the Federal Information Security Management Act (FISMA), Public Law (P.L.) 107-347.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[73]: "NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems...", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[74]: "This publication was developed by the Joint Task Force Transformation Initiative Interagency Working Group with representatives from the Civil, Defense, and Intelligence Communities...", NIST SP 800-39, σελ. 5 & NIST SP 800-30 Rev.1, σελ. 5

[75]: "March 2011", NIST SP 800-39, σελ. 1

[76]: "Special Publication 800-39 supersedes the original Special Publication 800-30 as the source for guidance on risk management.", NIST SP 800-39, σελ. 4

[77]: "September 2012", NIST SP 800-30 Rev.1, σελ. 1

[78]: "Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[79]: "This publication may be used by nongovernmental organizations on a voluntary basis...", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[80]: "...and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.", NIST SP 800-39, σελ. 3 & NIST SP 800-30 Rev.1, σελ. 3

[81]: "The guidelines in this publication are applicable to all federal information systems other than those systems designated as national security systems...", NIST SP 800-30 Rev.1, σελ. 2 & NIST SP 800-39, σελ. 3

[82]: "State, local, and tribal governments, as well as private sector organizations are encouraged to consider using these guidelines, as appropriate.", NIST SP 800-30 Rev.1, σελ. 2 & NIST SP 800-39, σελ. 3

[83]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reduces the burden on organizations that must conform to ISO/IEC and NIST standards.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 4

[84]: "This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[85]: "Attribution would, however, be appreciated by NIST.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[86]: "All NIST publications are available at <http://csrc.nist.gov/publications>.", NIST SP 800-30 Rev.1, σελ. 3 & NIST SP 800-39, σελ. 3

[87]: "To integrate the risk management process throughout the organization, a three-tiered approach is employed that addresses risk at the: (i) organization level; (ii) mission/business process level; and (iii) information system level.", NIST SP 800-39, σελ. 9

[88]: "Tier 1 addresses risk from an organizational perspective... Tier 1 implements the first component of risk management (i.e., risk framing), providing the context for all risk management activities carried out by organizations.", NIST SP 800-39, σελ. 9

[89]: "Tier 2 addresses risk from a mission/business process perspective... Tier 2 risk management activities include... establishing an enterprise architecture... Tier 2 activities directly affect the activities carried out at Tier 3.", NIST SP 800-39, σελ. 10

[90]: "Tier 3 addresses risk from an information system perspective... Tier 3 risk management activities include: (i) categorizing organizational information systems; (ii) allocating security controls... and (iii) managing the selection, implementation, assessment, authorization, and ongoing monitoring...", NIST SP 800-39, σελ. 10

[91]: "The risk management process is carried out seamlessly across the three tiers with the overall objective of... effective inter-tier and intra-tier communication... and a feedback loop for continuous improvement", NIST SP 800-39, σελ. 9

[92]: "NIST Special Publication 800-39 is the flagship document in the series of information security standards and guidelines developed by NIST in response to FISMA.", NIST SP 800-39, σελ. 3

[93]: "Risk assessment is a key component of a holistic, organization-wide risk management process as defined in NIST Special Publication 800-39", NIST SP 800-30 Rev.1, σελ. 4

[94]: "Special Publication 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems...", NIST SP 800-39, σελ. 4

[95]: "Special Publication 800-53, Recommended Security Controls for Federal Information Systems and Organizations", NIST SP 800-39, σελ. 4

[96]: "The concepts and principles... are intended to be similar to and consistent with the processes and approaches described in International Organization for Standardization (ISO)... reducing the burden on organizations", NIST SP 800-30 Rev.1, σελ. 3

[97]: "Risk management is a comprehensive process that requires organizations to: (i) frame risk... (ii) assess risk; (iii) respond to risk... and (iv) monitor risk on an ongoing basis", NIST SP 800-39, σελ. 6

[98]: "Risk management... ensuring that risk-based decision making is integrated... using effective organizational communications and a feedback loop for continuous improvement", NIST SP 800-39, σελ. 6

[99]: "Risk assessment activities can be integrated with the steps in the Risk Management Framework (RMF), as defined in NIST Special Publication 800-37.", NIST SP 800-30 Rev.1, σελ. 20

[100]: "risk assessments are conducted throughout the system development life cycle, from pre-system acquisition... through system acquisition... and on into sustainment", NIST SP 800-30 Rev.1, σελ. ix

[101]: "Risk, and its contributing factors, can be assessed in a variety of ways, including quantitatively, qualitatively, or semi-quantitatively.", NIST SP 800-30 Rev.1, σελ. 14

[102]: "Quantitative assessments typically employ a set of methods... based on the use of numbers... This type of assessment most effectively supports cost-benefit analyses... rigor... is significantly lessened when subjective determinations are buried", NIST SP 800-30 Rev.1, σελ. 14

[103]: "Qualitative assessments typically employ a set of methods... based on nonnumerical categories or levels... supports communicating risk results to decision makers... range of values... is comparatively small, making the relative prioritization... difficult", NIST SP 800-30 Rev.1, σελ. 14

[104]: "Semi-quantitative assessments typically employ a set of methods... that uses bins, scales, or representative numbers... This type of assessment can provide the benefits of quantitative and qualitative assessments... relative prioritization among results is better supported", NIST SP 800-30 Rev.1, σελ. 14

[105]: "A preferred approach (or situation-specific set of approaches) can be selected based on organizational culture and, in particular, attitudes toward the concepts of uncertainty and risk communication.", NIST SP 800-30 Rev.1, σελ. 14

[106]: "There are no specific requirements with regard to... formality, rigor... methodologies, tools... Organizations have maximum flexibility on how risk assessments are conducted", NIST SP 800-30 Rev.1, σελ. ix

[107]: "The templates are exemplary and can be tailored by organizations in accordance with specific organizational mission/business requirements.", NIST SP 800-30 Rev.1, σελ. 29

[108]: "The assessment scales in this appendix can be used as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, σελ. I-1

[109]: "The use of the templates is not required in order to conduct risk assessments.", NIST SP 800-30 Rev.1, σελ. 29

[110]: "A single risk model... cannot meet the diverse needs... The expectation... is that each organization... will define a risk model appropriate to its view of risk", NIST SP 800-30 Rev.1, σελ. 16

[111]: "Risk is a measure... typically a function of: (i) the adverse impacts... and (ii) the likelihood of occurrence.", NIST SP 800-30 Rev.1, σελ. 6

[112]: "Qualitative assessments typically employ... nonnumerical categories or levels (e.g., very low, low, moderate, high, very high).", NIST SP 800-30 Rev.1, σελ. 14

[113]: "The bins (e.g., 0-15, 16-35, 36-70, 71-85, 86-100) or scales (e.g., 1-10) translate easily into qualitative terms... while also allowing relative comparisons", NIST SP 800-30 Rev.1, σελ. 14

[114]: "Table I-2: Assessment Scale - Level of Risk (Combination of Likelihood and Impact)... High (Likelihood) + Moderate (Impact) = High (Risk)", NIST SP 800-30 Rev.1, σελ. I-1

[115]: "This broad definition also allows risk to be represented as a single value or as a vector (i.e., multiple values), in which different types of impacts are assessed separately.", NIST SP 800-30 Rev.1, σελ. 12

[116]: "Uncertainty is inherent in the evaluation of risk... The degree of uncertainty... can be communicated in the form of the results", NIST SP 800-30 Rev.1, σελ. 13

[117]: "The taxonomy and assessment scales in this appendix can be used by organizations as a starting point with appropriate tailoring to adjust for any organization-specific conditions.", NIST SP 800-30 Rev.1, σελ. D-1

[118]: "In general, types of threat sources include: (i) hostile cyber or physical attacks; (ii) human errors... (iii) structural failures... and (iv) natural and man-made disasters", NIST SP 800-30 Rev.1, σελ. 8

[119]: "Appendix D... (ii) an exemplary taxonomy of threat sources... (iii) an exemplary set of tailorable assessment scales for assessing those risk factors", NIST SP 800-30 Rev.1, σελ. D-1

[120]: "Appendix E... (ii) representative examples of adversarial threat events expressed as tactics, techniques, and procedures (TTPs) and non-adversarial threat events", NIST SP 800-30 Rev.1, σελ. E-1

[121]: "Predisposing conditions... contribute to (i.e., increases or decreases) the likelihood that one or more threat events... result in adverse impacts... (e.g., the location of a facility in a hurricane- or flood-prone region... or a stand-alone information system)", NIST SP 800-30 Rev.1, σελ. 10

[122]: "Organizations can eliminate certain threat events from further consideration if no adversary with the necessary capability has been identified. Organizations can also modify the threat events provided", NIST SP 800-30 Rev.1, σελ. E-1

[123]: "Managing risk is a complex, multifaceted activity that requires the involvement of the entire organization from senior leaders/executives... to individuals on the front lines", NIST SP 800-39, σελ. 6

[124]: "The risk executive (function) requires a mix of skills, expertise, and perspectives... supported by an expert staff", NIST SP 800-39, σελ. 13

[125]: "Individuals with information security/risk assessment and monitoring responsibilities (e.g., system evaluators, penetration testers, security control assessors...)", NIST SP 800-30 Rev.1, σελ. 3

[126]: "The risk management process is carried out seamlessly across the three tiers... effective inter-tier and intra-tier communication", NIST SP 800-39, σελ. 9

[127]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, σελ. 47

[128]: "This publication is intended to serve a diverse group... Individuals with oversight responsibilities... (e.g., heads of agencies, chief executive officers...)", NIST SP 800-39, σελ. 3

[129]: "The risk executive (function) serves as the common risk management resource for senior leaders/executives... authorizing officials... security control assessors", NIST SP 800-39, σελ. 12

[130]: "Appendix K provides the essential elements of information that organizations can use to communicate the results of risk assessments... (i) an executive summary; (ii) the main body... and (iii) supporting appendices.", NIST SP 800-30 Rev.1, σελ. K-1

[131]: "The fourth component of risk management addresses how organizations monitor risk over time... verify that planned risk response measures are implemented... determine the ongoing effectiveness", NIST SP 800-39, σελ. 7

[132]: "Where automated monitoring is feasible, it should be employed because it is generally faster, more efficient, and more cost-effective than manual monitoring.", NIST SP 800-39, σελ. 47

Tools

[133]: SimpleRisk Pricing & Licensing Model | SimpleRisk
<https://www.simplerisk.com/pricing>

[134]: Manual Installation Download Form | SimpleRisk
<https://www.simplerisk.com/download/manual>

[135]: Try SimpleRisk: Demo, Trial & Sandbox Options | SimpleRisk
<https://www.simplerisk.com/try>

- [136]: What are the requirements for me to run SimpleRisk? | SimpleRisk Support
<https://simplerisk.freshdesk.com/support/solutions/articles/6000156747-what-are-the-requirements-for-me-to-run-simplerisk->
- [137]: SimpleRisk Sandbox Environment (Screenshots: Self Assessments Menu) | SimpleRisk Demo <https://demo.simplerisk.com>
- [138]: Details about the ISMS-Tool verinice.
<https://verinice.com/en/products/verinice/about-verinice>
- [139]: Software. <https://shop.verinice.com/en/Software/>
- [140]: verinice Standalone for information security management.
<https://verinice.com/en/products/verinice/verinice-standalone>
- [141]: verinice. (2020) verinice Demo: Establishing an ISMS according to ISO 27001.
https://www.youtube.com/watch?v=vB-xLN_vZnY
- [142] EAR - Environment for the Analysis of Risk. <https://www.pilar-tools.com/en/>
- [143] CCN-CERT, "PILAR - What is PILAR?". <https://pilar.ccn-cert.cni.es/en/pilar-solution/what-is-pilar>
- [144] PILAR Basic - User's Manual (2025), Chapter I: Introduction
- [145] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1. Essential assets)
- [146] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.2. Support assets / II.3. Automation)
- [147] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.1.2. Rating)
- [148] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4. Security profiles)
- [149] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation) & Chapter IV: Advanced user (IV.1. Threats)
- [150] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.3. Automation)
- [151] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.3. Rating)
- [152] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.4.4 Traffic light)
- [153] PILAR Basic - User's Manual (2025), Chapter II: Novice user (II.5. Reporting)
- [154] MONARC Project, "Documentation & Project Identity".
<https://www.monarc.lu/documentation/>
- [155] MONARC Project, "Quick Start Guide». <https://www.monarc.lu/documentation/quick-start/>

- [156] MONARC Project, "Technical Guide (Architecture & Requirements)".
<https://www.monarc.lu/documentation/technical-guide/>
- [157] MONARC Documentation - User Guide, "Risk Analysis: Asset Definition & Tree Structure". <https://www.monarc.lu/documentation/user-guide/>
- [158] MONARC Documentation - Method Guide, "Libraries & Objects Management".
<https://www.monarc.lu/documentation/method-guide/>
- [159] MONARC Documentation - Method Guide, "Risk Calculation & Assessment Scale". <https://www.monarc.lu/documentation/method-guide/>
- [160] MONARC Documentation - User Guide, "Reporting & Exports (SoA, Risk Treatment)". <https://www.monarc.lu/documentation/user-guide/>
- [161] MONARC Documentation - User Guide, "Dashboard & Interface Overview".
<https://www.monarc.lu/documentation/user-guide/>
- [162] MONARC Documentation - Method Guide, "Context Modelling & Inheritance".
<https://www.monarc.lu/documentation/method-guide/>
- [163] MONARC Project, "Features & Usability (Optimised Method)".
<https://www.monarc.lu/product/>